FAST. SECURE. GLOBAL.

Network security challenges in 2015

Robert Dąbrowski, CISSP

© Copyright Fortinet Inc. All rights reserved.

http://threatmap.fortiguard.com/

NSS Cyber Advanced Warning System™ (CAWS)

- **Warnings of Imminent Danger**
  - » Real-time tracking of the adversaries' capabilities.
  - » Real-time alerts when an application is exploited.
  - » Real-time alerts of when an attack bypasses a security product or layers of products.

- **Indicators of Compromise**
  - » Malicious URL and IP Address
  - » Dropped Malware and hashes
  - » Command and control servers

- **Dynamic Analytics**
  - Global or specific location
  - Trends (weekly, monthly, yearly)
  - Focus on **protection** (security products), **attack surface** (applications), **deployment** (location) or individual **threats**
  - Analyze threats by operating system, browser or business application.

Source: https://www.nsslabs.com/cyber-advanced-warning-system-caws

Sony Breach

- The attack vector has not been released, but some resources state that the malware used contained stolen username and password (Administrators) which would indicate that credentials were stolen from a phishing email. The malware known as wiper was able to overwrite the Master Boot Record (MBR) and all data files on the computers.
- It is most likely that the infiltration happened over the course of **several months and remained undetected** until the day the malware was released
- This is an ongoing challenge for a lot of large companies where response to attacks are **mostly reactive instead of early detection and adequate mitigation**.

Source: http://a3.mzstatic.com/us/r30/Video5/v4/1d/43/1e/1d431e3b-1790-0796-8dfc-06ae246061c7/poster227x227.jpeg

Ghost Exploit

- The __nss_hostname_digits_dots() function in glibc was found vulnerable to a heap-based buffer overflow. This function is used by libc DNS resolution functions gethostbyname*().
- Any application making use of the DNS resolution service can be used to exploit the vulnerability, potentially **allowing a remote attacker to execute arbitrary code with the permissions of the user running the application**.

Anthem Data Breach

- 80 Million SIN
- Stolen Credentials
- The attack used a stolen administrator ID which had access to sensitive data. The breach was discovered by a database administrator. The administrator identified his login making a suspicious database query that was not initiated by him. Once the query was identified Anthem's Information Security Department was alerted. **Further investigation revealed other database administrator's credentials were compromised**.

Carbanak

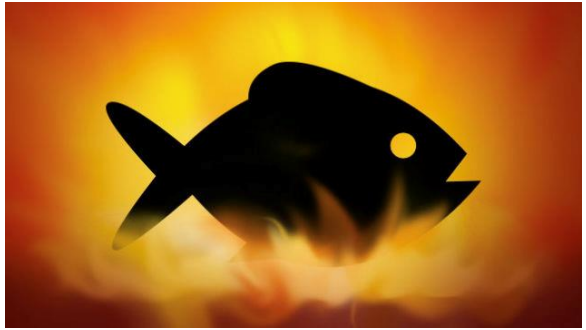
- A group of cybercriminal used social engineering to install **remote access toolkits (RATs)** to steal over $1 bln from banks and other financial institutions. Banks in Russia, USA, Germany, China, and Ukraine were the most heavily targeted.
- Details around the attack suggest attackers initially compromised low value systems, and then used other attack techniques to pivot and compromise higher value targets, deeper in the bank's networks. This method is often referred to as **lateral movement in an APT context**.

EQUATION – FANNY Worm

- Used 0-days before Stuxnet (FANNY Worm)
- Spread via USB/Web/Physical Media
- Hard Drive Firmware Infection
- As mentioned above, the FANNY worm made use of two 0-day exploits that were later incorporated by Stuxnet. This also hints at the possibility that the Equation group and Stuxnet developers are either the same or working closely together. **The GRAYFISH component also uses decryption mechanisms similar to Gauss, which has already been found to be a successor of Stuxnet**.

Superfish

- The proxy mainly intercepts HTTPS traffic, creates a certificate for the website *on-the-fly* and uses this certificate to pass on traffic to the browser. The **certificate will be approved** by the browser thanks to the Superfish Root CA on the machine.

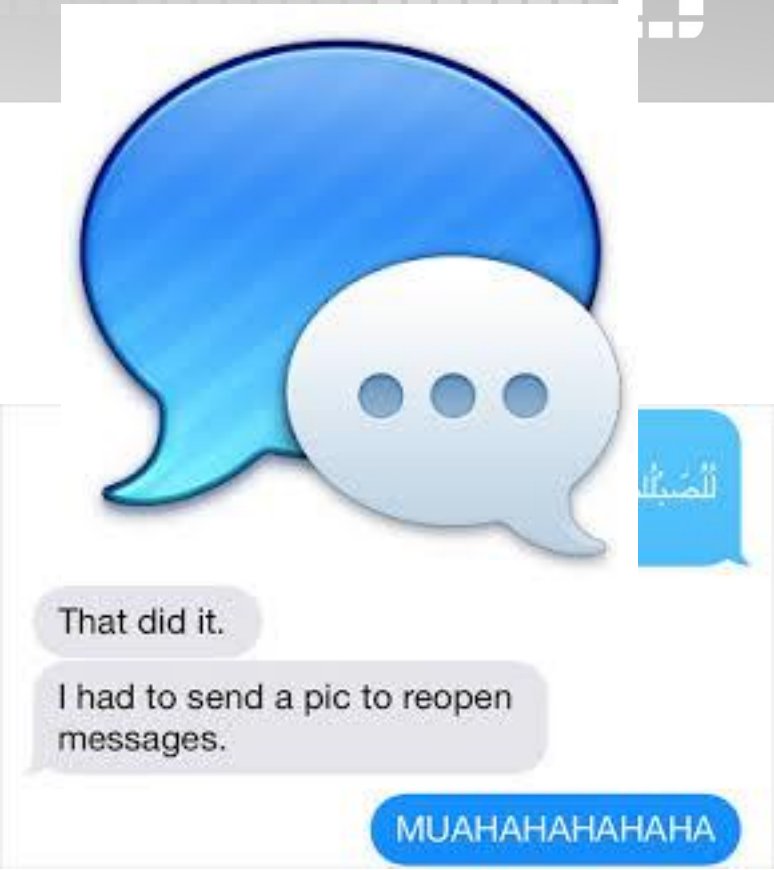


iReboot IOS Unicode Vuln.

- Technically speaking, **it does not *reboot* the device, but only ‘re-springs’ the SpringBoard**. However, as restarting the SpringBoard kills all running applications and takes a few seconds, for the end-user the result is basically the same (which explains why so many articles talk about 'rebooting' the device).
- Is this likely to affect me?

Obviously, the difficulty is not in sending an SMS, but in finding the right SMS string to send. Most copy / pastes of SMS messages found on the Internet do not work: you need to test several variations to get it work.

This fortunately limits the spread of the issue..



Stagefright - Android

- 7 CVE - CVE-2015-1538, CVE-2015-1539, CVE-2015-3824, CVE-2015-3826,CVE-2015-3827, CVE-2015-3828, and CVE-2015-3829
- Upon receiving the malicious message, the application responsible for handling such messages displays a preview of the received message in the *Notifications* Shade. An effective exploit would result in the **vulnerable code being triggered on the phone**.

uConnect

- 1.4 Million vehicles recalled
- This vulnerability could allow an attacker to send commands the car's dashboard functions, **steering, brakes and transmission** from a remote location.
- Chrysler has also implemented what they call, "network-level security measures" – blocking the attack from passing over Sprint's cellular network (Sprint is the connectivity provider in the USA for the Uconnect system). FCA believes this will ensure that vehicles that do not update Uconnect will still be protected from this attack at the network level.

iOS XcodeGhost Malware

iOS/XcdGhost.A!tr is famous for being the first iOS malicious compiler, and the first to infect several applications in Apple's AppStore.

Applications infected with XcodeGhost upload system information to a remote C&C server. They also show the capability of displaying an alert, opening specific URLs sent by the C&C and using the user's clipboard.

Source: https://www.google.pl

Ashley Madison Hack

- 32 million accounts details
- $576 million class-action lawsuit

Effects of DDoS Attacks

"**DDoS attacks are often used as a distraction technique for ulterior motives**. They're not always intended for denying service, but rather as a means of obfuscation, intended to degrade security defenses, overwhelm logging tools and distract IT teams while various forms of malware sneak by,"

" **Approximately 50 percent of respondents rely on traditional IT infrastructure**, such as firewalls or Intrusion Prevention Systems to protect against DDoS attacks, or they depend on their upstream provider to deal with the attacks. **Only 23 percent of those surveyed have dedicated DDoS protection** via an on-premises appliance-based technology or from an anti-DDoS cloud service provider."

DDoS Service Provider

Managed service subscription model usually with separate detection and mitigation.

Pros:

- Easy sign up
- Easy deployment

Cons:

- Expensive overages
- Unpredictable costs
- Limited flexibility

Firewall/IPS

Integrated device that includes firewall, intrusion protection and DDoS prevention.

Pros:

- Single device
- Less units to manage

Cons:

- Poor level 7 attack detection
- May require licensing
- Performance impacts

Dedicated Appliance

Inline data center appliance that provides layer 3, 4 and 7 DDoS detection and mitigation.

Pros:

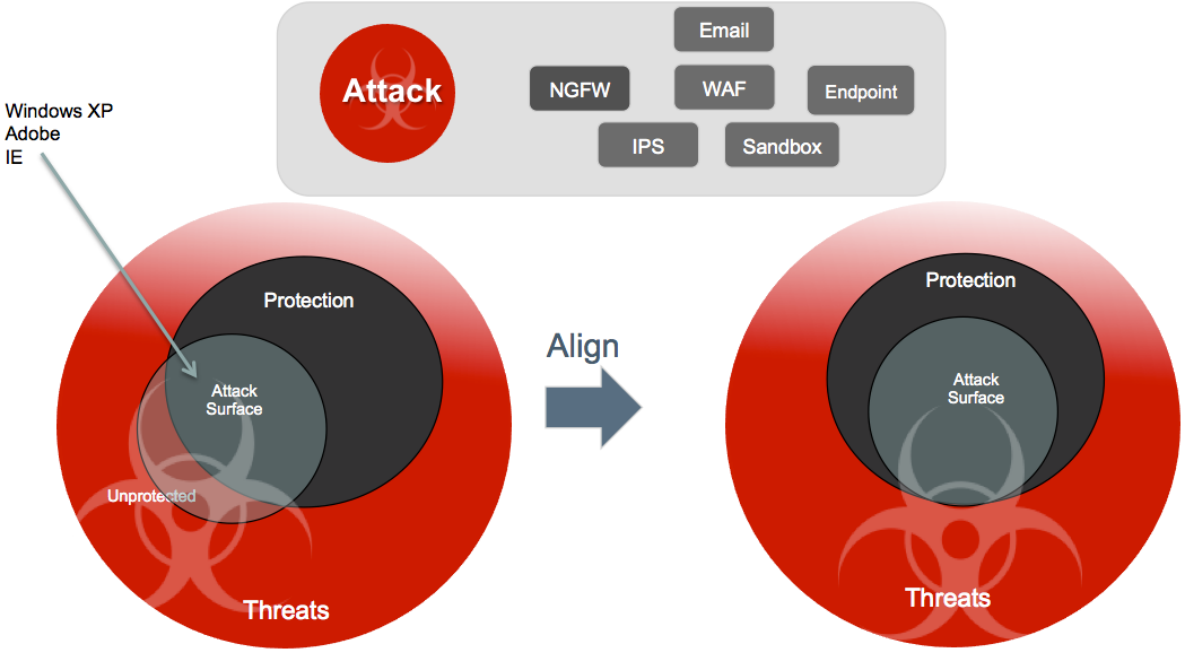
- Predictable costs
- Advanced layer 7 protection

Cons*:

- Additional device management
- Can be vulnerable to large attack
- May require signature updates
- Expensive for high-performance

Source: http://www.darkreading.com/attacks-breaches/corero-network-security-survey-finds-degradation-of-customer-confidence-and-lost-revenues-are-the-most-damaging-ramifications-of-ddos-attacks/d/d-id/1321293

Protecting the Attack Surface Is Critical



What matters are the *threats* that get through *your security* and exploit *your assets* – not worldwide threats!

Ensure *Your Security* is protecting you against the *threats* relevant to *your assets*

THANK YOU!!!

robert.dabrowski@fortinet.com